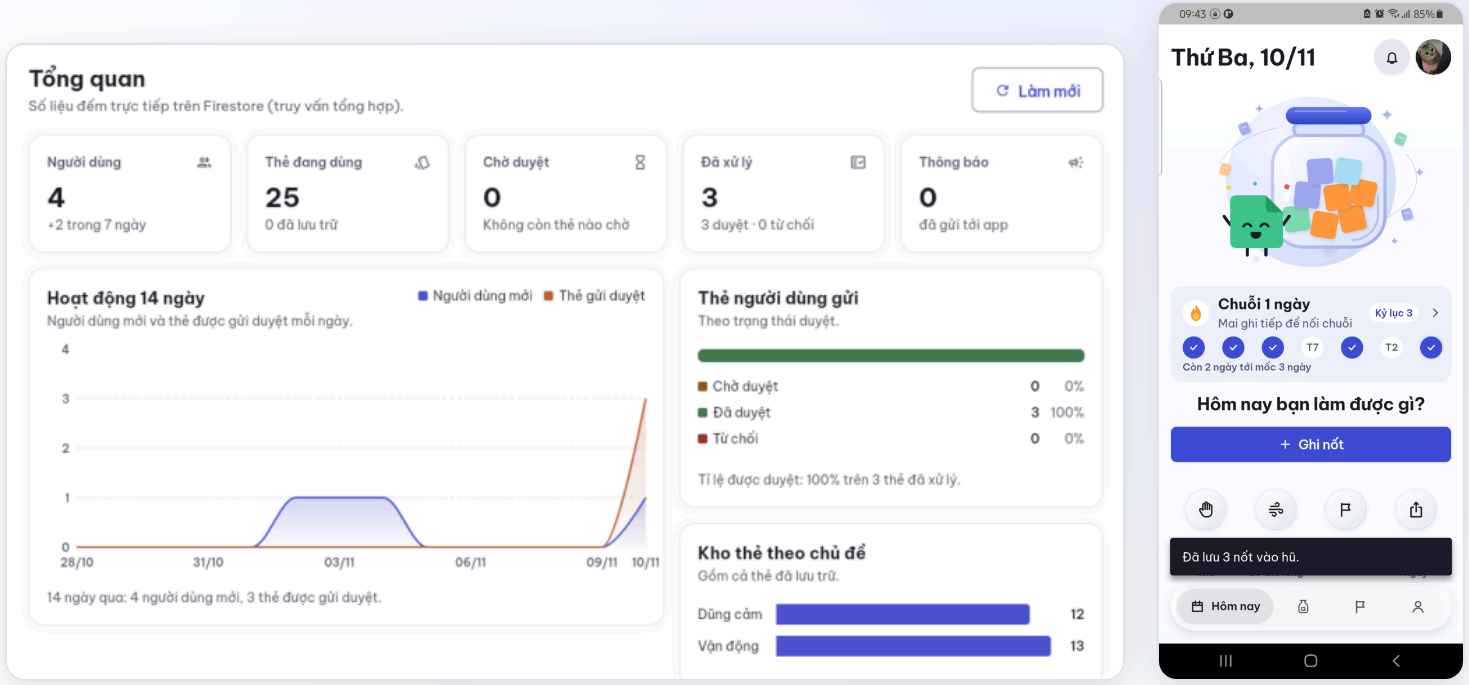
FPT Education
FPT UNIVERSITY

Nốt

One positive note every day, now with staff, AI and a shared catalog

Đoàn Thị Kim Thúy · SE190992
Phùng Thế Quân · SE193519
Phan Đức Duy · SE193591
Phan Hữu Phước · SE161951



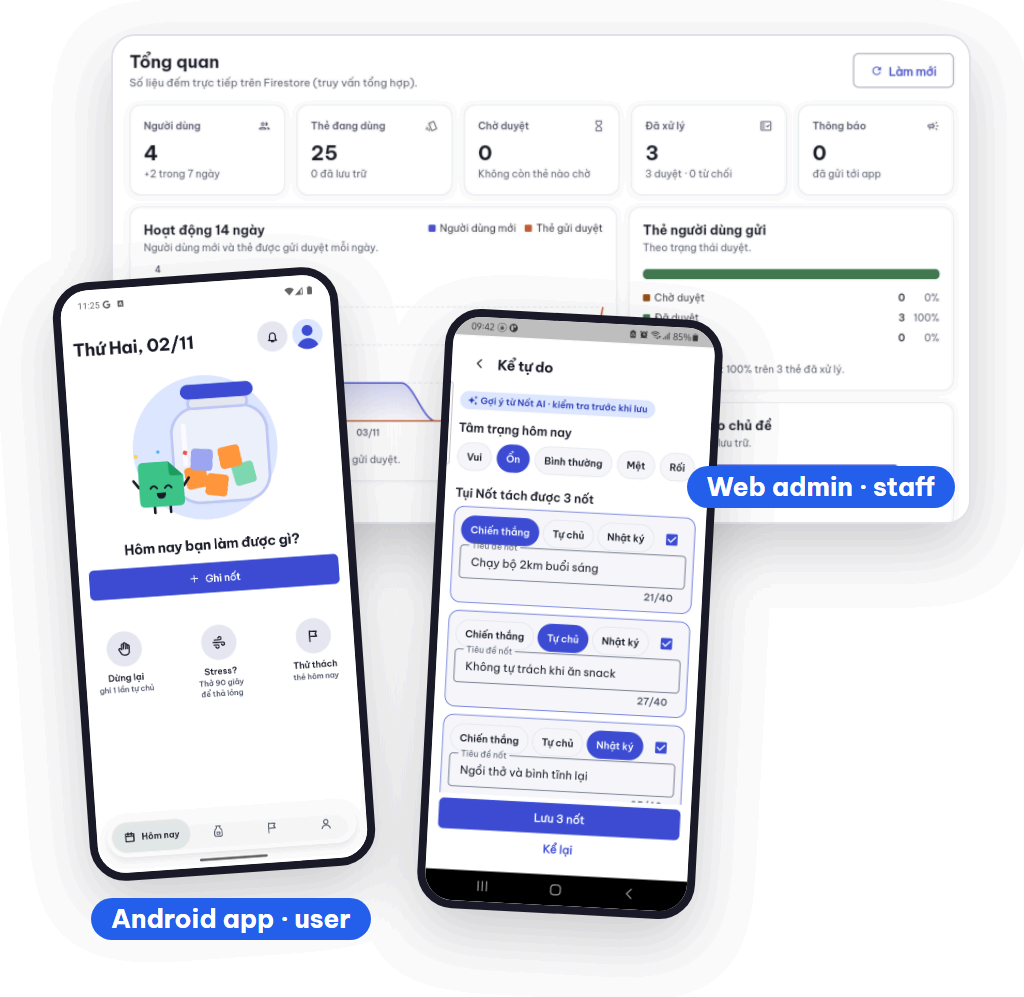
FPT Education
FPT UNIVERSITY

Nốt is a daily-wins app with a staff web admin, running on one Firebase project

Users	Platform	Backend
Students · staff · admins	Flutter Android + Web	Firebase, no server

Value

Log one small win in **under 30 s**, get fresh challenge cards and news **without updating the app**.



What the Final added on top of Lab 3

Roles + web admin
user / staff / admin · 5 screens

Cross-role flow
share → approve → live update

Nốt AI
one paragraph → sorted notes

Inbox · onboarding · PDF
news live · starter plan · weekly card

Live: prm393-not-lab3.web.app (app) · prm393-not-lab3.web.app/admin/ (web admin) · repo FU-PRM-Projects/Lab-03

FPT Education
FPT UNIVERSITY

Minh ends most evenings remembering what he did not finish

Lab 2 persona and the habit Nốt was designed around; Lab 3 shipped it for one person, alone.

PERSONA

Minh, 22, final-year student, worn out. Ends the evening looking at the list of unfinished tasks instead of what went well.

SUCCESS CRITERION (LAB 2)

Log a mood and one small win in **under 30 seconds** after tapping the evening reminder.

HOW NỐT WORKED AFTER LAB 3

- One user, own data only (notes, habits, groups)
- Challenge cards: a fixed seed list in Firestore
- Own cards stayed private to their author

WHO ELSE IS INVOLVED NOW

- Staff who write and curate challenge cards
- An admin who decides who is staff
- Gemini, to cut typing in the evening



Weekly card, Lab 3 flow kept in the Final

Source: Lab 2 persona and success criterion (README, docs/design-traceability.md).

Three gaps kept Nốt from being a system: no curator, no channel, slow evenings

Each pain point is answered directly on the next slide.

Static challenge content

CAUSE

Cards were a seed list; changing one needed a developer and a script

IMPACT

Users run out of fresh cards; good ideas from users stay private

No way to reach users

CAUSE

No staff role, no announcements, push only from the Console

IMPACT

Nobody can tell users about new cards or events inside the app

Logging takes effort at night

CAUSE

Each note is typed and classified by hand (win, self-control, journal)

IMPACT

The 30 s goal slips when the day had several moments to record

Lab 3 flow left unfinished

CAUSE

The weekly card PDF went to Cloud Storage, which needs the paid plan

IMPACT

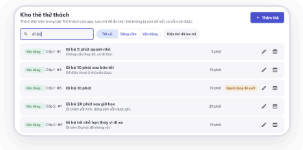
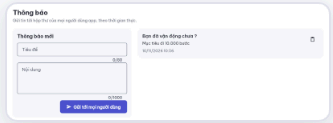
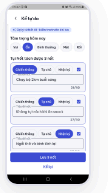
Export never worked on the real project

Evidence: docs/gap-review.md (Lab 2 / Lab 3 gaps before the Final). No user survey was run; impacts are observed in the Lab 3 build.

FPT Education
FPT UNIVERSITY

One Firebase system: a staff web admin, a review flow, and Gemini that sorts the day

Every pain point maps to a feature that is live and demonstrated.

PAIN POINT	SOLUTION	EXPECTED VALUE	LIVE
Static content	Web admin catalog + users share cards, staff approve	Catalog grows without a release	
No channel	Announcements + personal inbox (Firestore, real time)	News lands in the app in the same minute	
Slow evenings	Nốt AI: tell the day once, confirm sorted notes	Several notes from one paragraph	
Broken PDF	Build and save the PDF on the device, metadata in Firestore	Works on the free plan, offline	

IN SCOPE (MVP)

- WF-01 Log the day with Nốt AI
- WF-02 Publish a user card to the catalog
- WF-03 Announce news to every user
- Onboarding, weekly PDF, roles, App Check

OUT OF SCOPE

- Cloud Functions, Cloud Storage (brief + paid plan)
- AI level 3 "Hỏi Nốt" (bonus, not built)
- iOS build

FPT Education
FPT UNIVERSITY

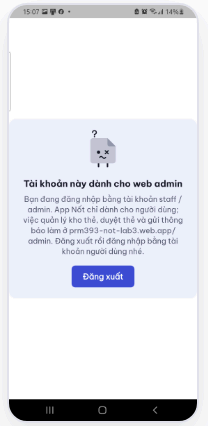
Three human roles and two external services, enforced by Security Rules

The role lives in users/{uid}.role; only an admin changes it, and never their own.

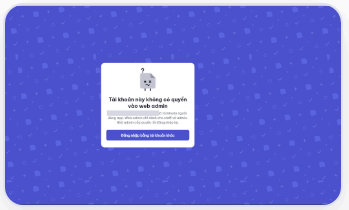
ACTOR	CLIENT	WHO	MAIN PERMISSIONS
User	Android app	Student using Nốt every evening	Own notes and data; share own cards (pending only); read catalog, announcements, own inbox
Staff	Web admin	Content curator	Create, edit, archive catalog cards; approve / reject with reason; post announcements
Admin	Web admin	Team lead	Everything staff can do + change other users' roles
Gemini	External	Firebase AI Logic, Gemini Developer API	Receives the scrubbed paragraph only; returns JSON suggestions
Firebase	Platform	Auth, Firestore, App Check, RC, FCM…	Rules decide every read and write; no custom server



Admin changes roles (own role locked)



Staff/admin on the phone



User on the web

First admin: set in the Firebase Console (Thị Kim Thúy Đoàn). Rules tests R-01…R-30 cover every role and collection (BR-05: R-26).

FPT Education
FPT UNIVERSITY

Three core workflows carry the demo; everything else supports them

Each workflow has an actor, a trigger and a business result, not a list of buttons.

WF-01

Log the day with Nốt AI

ACTOR	User
TRIGGER	Evening, user taps Ghi nốt → Kể tự do
RESULT	**Notes saved after the user confirms**
RULES	BR-01 · consent, Gemini JSON, edit, fallback
SOLVES	Slow evenings

WF-02

Publish a user card to the shared catalog

ACTOR	User + Staff
TRIGGER	User shares an own card
RESULT	**Card in the catalog, app updates, inbox message**
RULES	BR-02 submit · BR-03 approve / reject + reason
SOLVES	Static content

WF-03

Announce news to every user

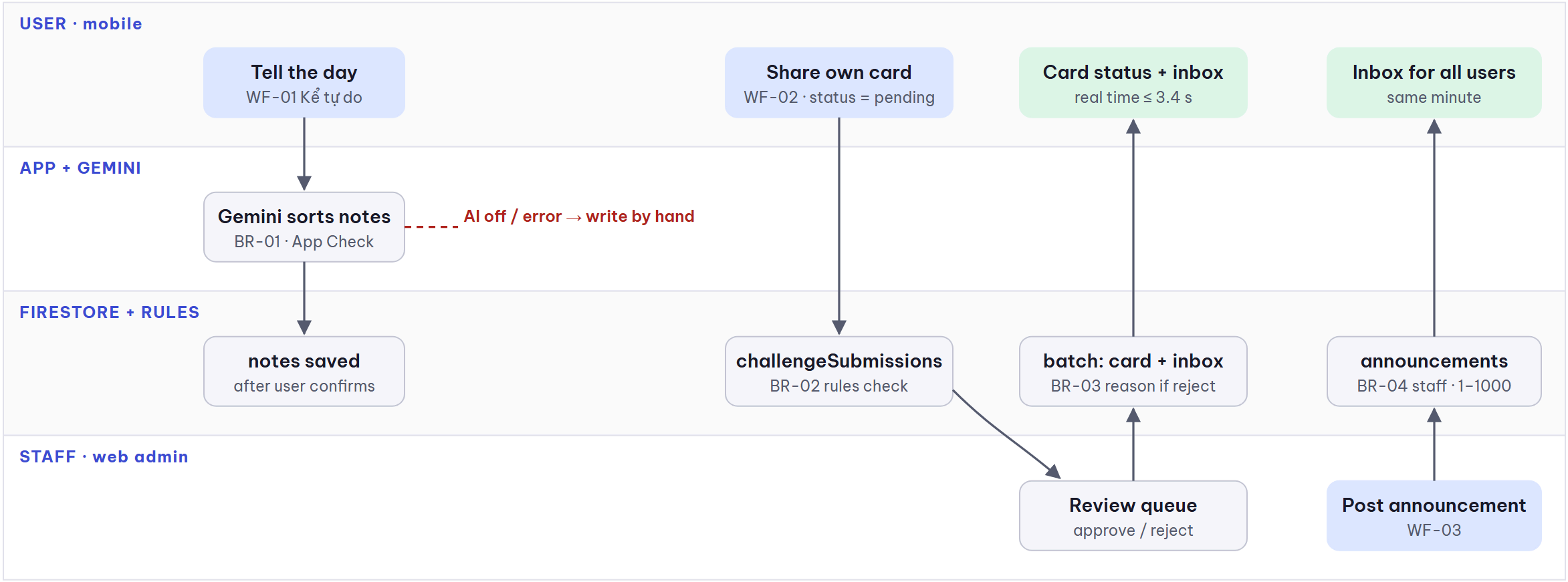
ACTOR	Staff
TRIGGER	Staff has news for everyone
RESULT	**Announcement published; every inbox shows it**
RULES	BR-04 title 1–80, body 1–1000, staff only
SOLVES	No channel

Supporting features: onboarding & starter plan · weekly card PDF · streaks & journey · self-control & breathing · groups · Discord link · dashboard · roles.

FPT Education
FPT UNIVERSITY

One swimlane view: who acts, where the data lands, where it branches

The three workflows share one Firestore; rules are the decision points.

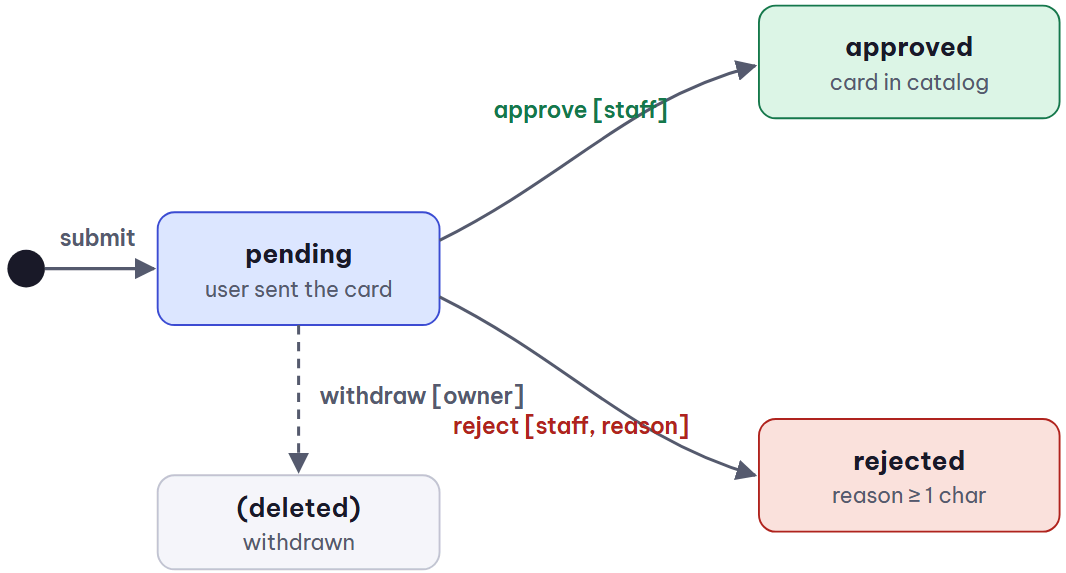


BR-01 AI only when enabled, consented and App Check passes · BR-02 user creates pending only · BR-03 reject needs a reason · BR-04 announcements: staff only, title 1–80, body 1–1000 · BR-05 only admins change roles, never their own.

FPT Education
FPT UNIVERSITY

A shared card moves pending → approved or rejected, and nowhere else

Entity: challengeSubmissions/{id}. Every transition and every forbidden one has a rules test.



Forbidden (rules deny)

user → approved
approved → pending
reject without reason
withdraw after review

```
109                     && request.resource.data.createdAt == request.time;
110         // Only pending -> approved | rejected; a rejection needs a reason.
111         allow update: if isStaff()
112                       && resource.data.status == 'pending'
113                       && request.resource.data.status in ['approved', 'rejected']
114                       && request.resource.data.diff(resource.data).affectedKeys()
115                            .hasOnly(['status', 'reason', 'reviewedAt', 'reviewedBy'
116                       && request.resource.data.reviewedBy == request.auth.uid
117                       && request.resource.data.reviewedAt == request.time
118                       && shortText(request.resource.data.get('reason', ''), 0, 200)
119                       && (request.resource.data.status == 'approved'
```

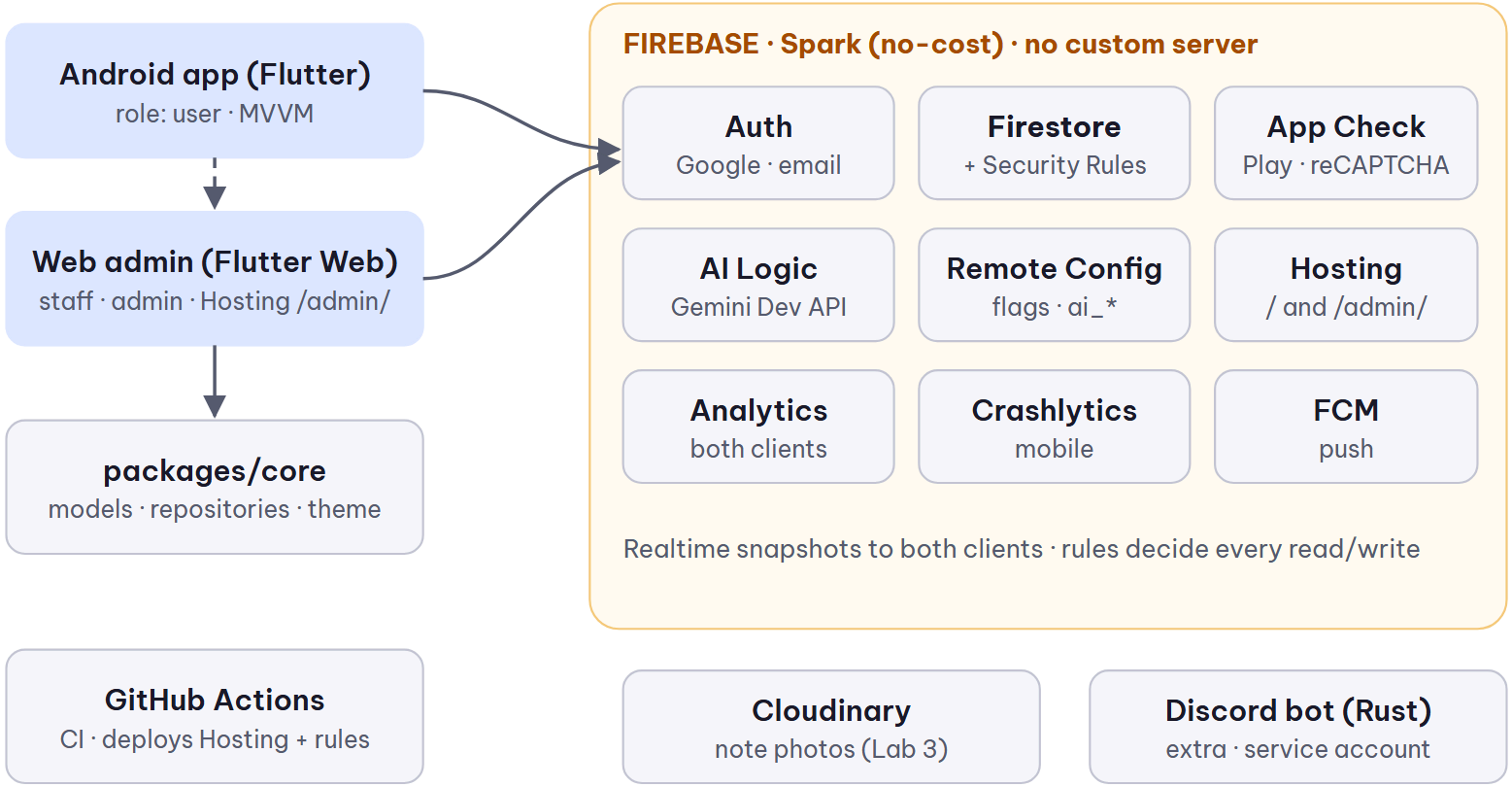
firestore.rules · the guard on every review (BR-03)

Tests: R-20 create pending only · R-21 read own or staff · R-22 staff review, reason on reject · R-23 withdraw while pending. 30/30 rules tests pass.

FPT Education
FPT UNIVERSITY

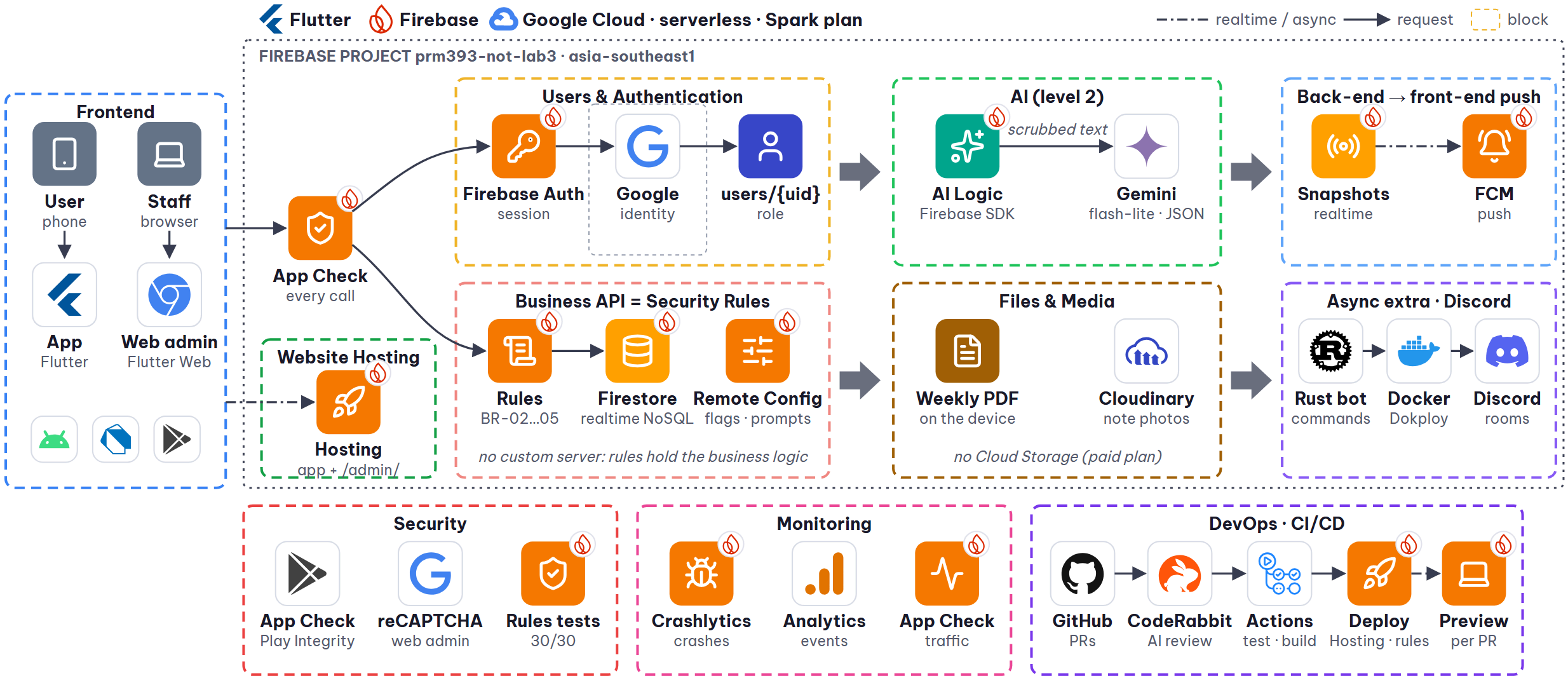
Two Flutter clients, one shared package, Firebase as the only backend

Decision: no custom server. Security Rules + App Check are the backend's access layer.



Deploy: GitHub Actions builds both clients, deploys Hosting (/ and /admin/) and Firestore rules + indexes on merge to main.

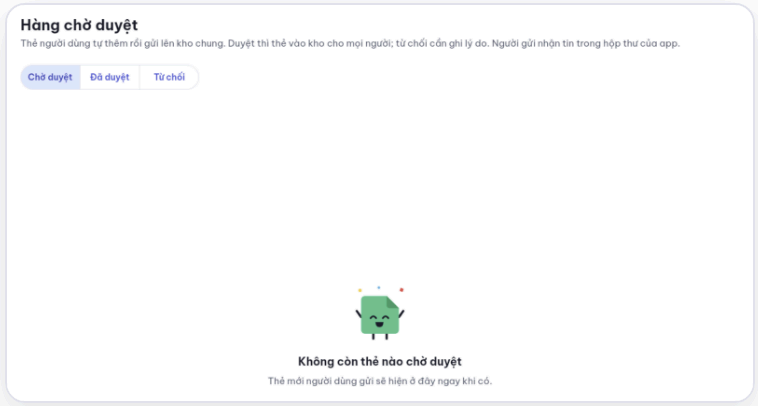
Serverless on Firebase: Security Rules are the backend



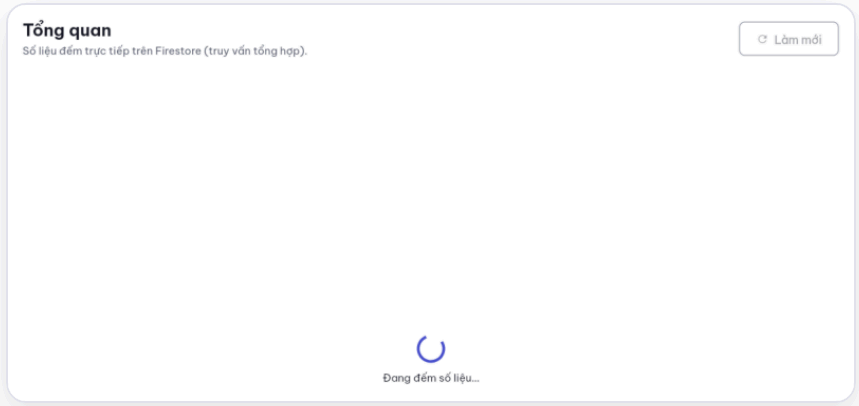
FPT Education
FPT UNIVERSITY

One design system across phone and web, with every UI state designed

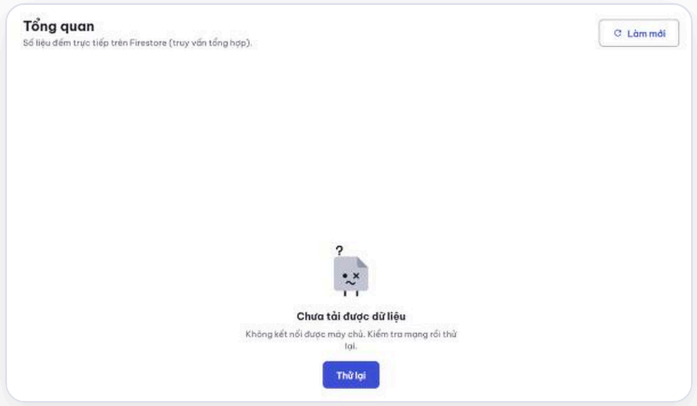
Lab 2 tokens live in packages/core; the web admin reuses them in a wide layout.



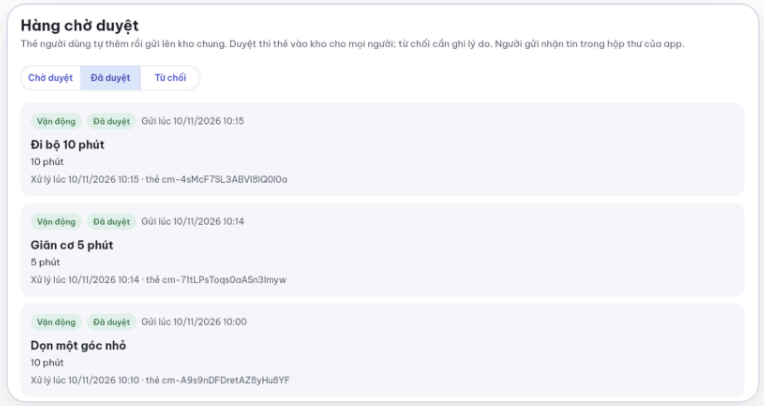
Empty · Hàng chờ duyệt



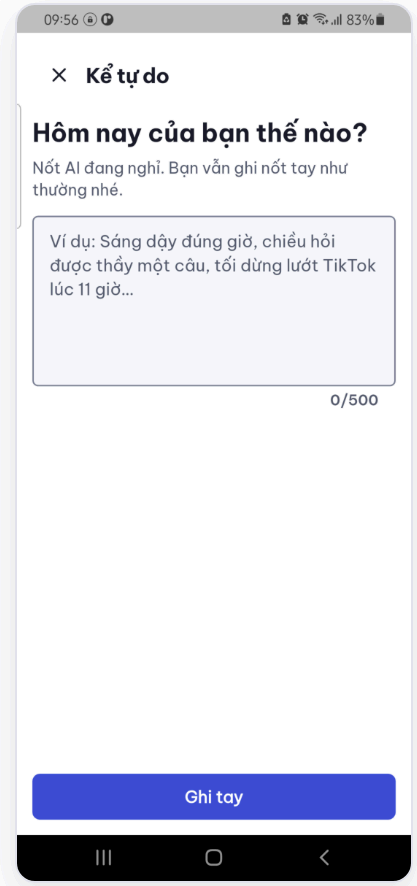
Loading · Tổng quan



Error · server unreachable, Thử lại



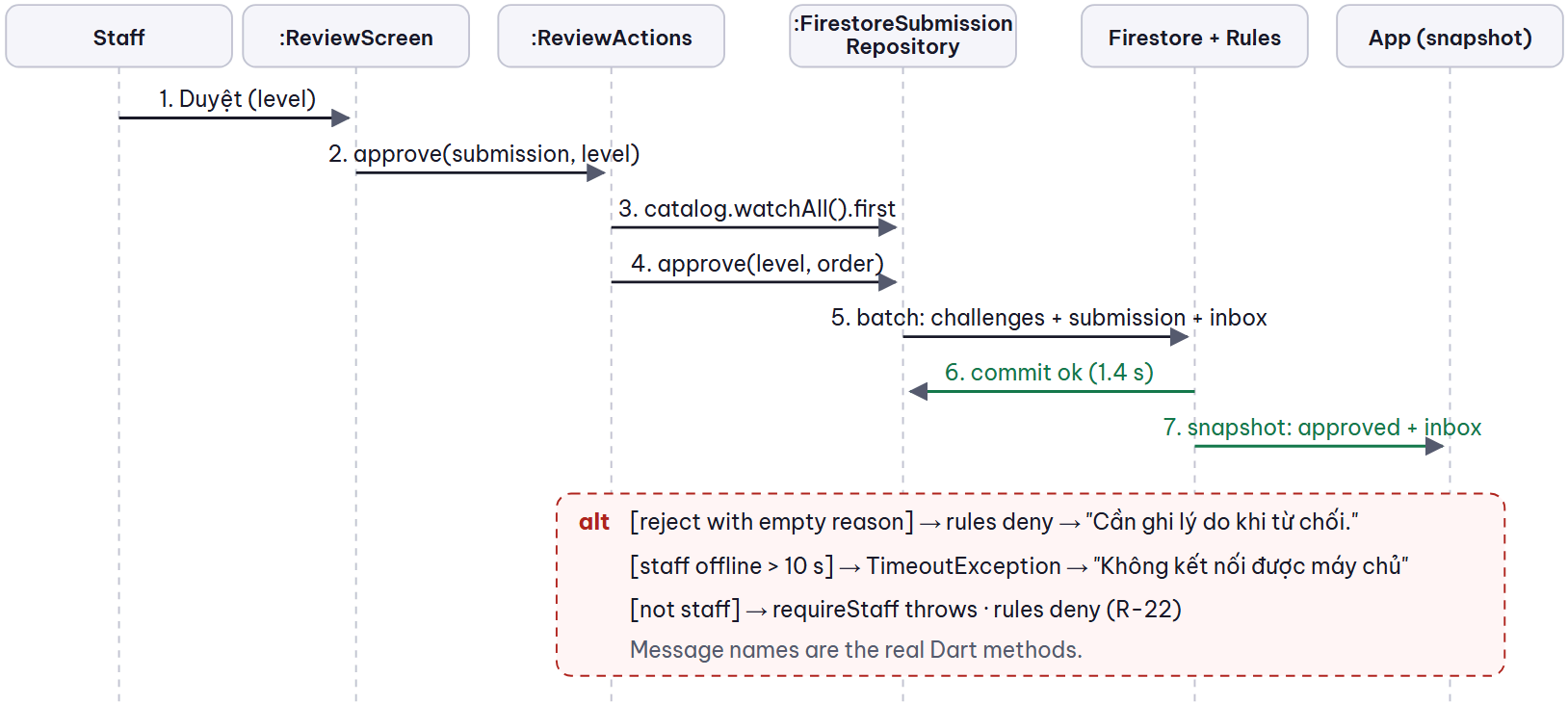
Success · approved cards



App · AI off state

States: empty · loading · error (within 15 s, Thử lại) · success · wrong role rejected on web and mobile.

Approving a card is one batch write; rules guard it, snapshots carry it back




```
        })
        ..update(_col.doc(submission.id), <String, Object?>{
          'status': SubmissionStatus.approved.id,
          'reason': '',
          'challengeId': cardId,
          'reviewedBy': reviewerUid,
          'reviewedAt': FieldValue.serverTimestamp(),
        })
        ..set(_inbox(submission.uid).doc(), <String, Object?>{
          'kind': InboxKind.submissionApproved.id,
          'title': 'Thẻ của bạn đã vào kho chung',
          'body': _clip(
            '"${submission.title}" đã được duyệt. Mọi người giờ có thể nhận '
            'thẻ này ở tab Thử thách.',
            500,
          ),
          'submissionId': submission.id,
          'read': false,
          'createdAt': FieldValue.serverTimestamp(),
        });
      await batch.commit();
    });
```

FirestoreSubmissionRepository.approve: one batch

FPT Education
FPT UNIVERSITY

MVVM in both clients: screens never touch Firebase directly

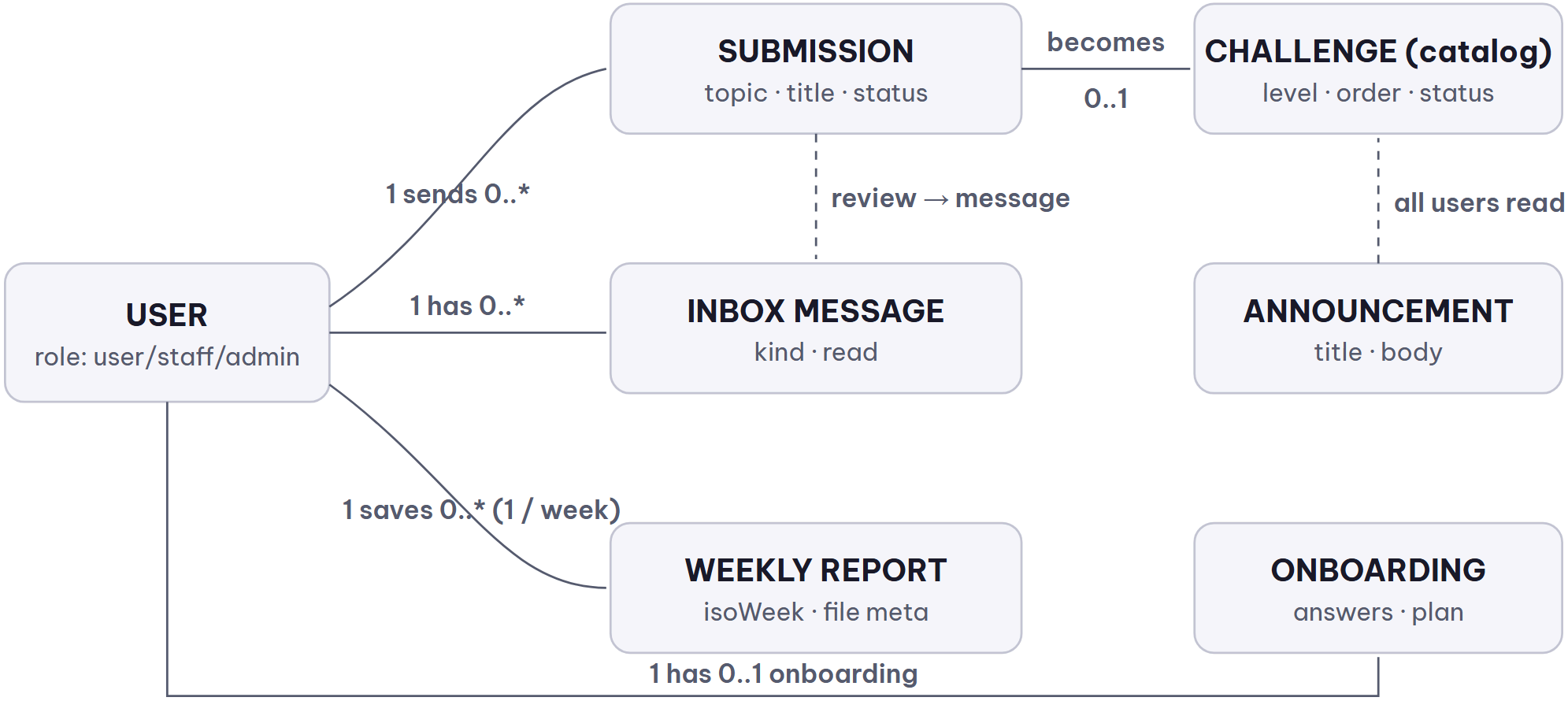
Business rules sit in the repository + Security Rules, not in widgets.

LAYER	WF-01 NỐT AI	WF-02 SHARE & REVIEW	WF-03 ANNOUNCE
Screen	`FreeTellScreen`	`ChallengesScreen` · `ReviewScreen`	`AnnouncementsScreen` · `NotificationInboxSheet`
ViewModel	`FreeTellViewModel`	`CommunityActions` · `ReviewActions`	`AnnouncementActions` · `communityInboxProvider`
Service	`AiService`	`SubmissionRepository` · `CatalogRepository`	`AnnouncementRepository` · `InboxRepository`
Implementation	`FirebaseAiService`	`FirestoreSubmissionRepository`	`FirestoreAnnouncementRepository`
Model	`AiSortResult` · `AiNoteSuggestion`	`ChallengeSubmission` · `CatalogCard`	`Announcement` · `InboxMessage`

main.dart wires each provider to its Firebase implementation; tests swap in fakes (303 app · 14 web admin · 5 core tests).

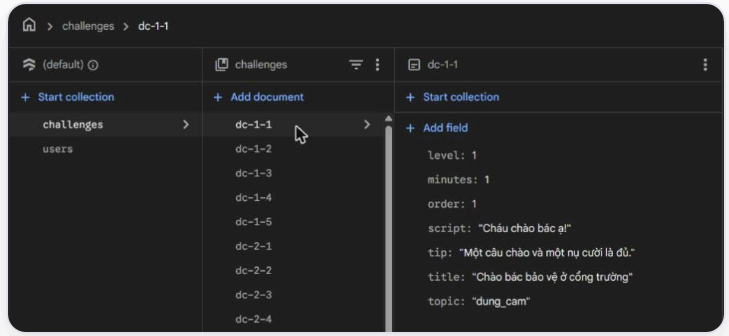
The Final added six entities around the user

Lab 3 entities (notes, habits, groups, progress) stay private to their owner.



Firestore collections, with constraints written as Security Rules

COLLECTION	KEY FIELDS	CONSTRAINTS (RULES)
users/{uid}	role, displayName, email	self-create as user; only admin changes role, never own
challenges/{id}	topic, level 1–10, order, title ≤ 80, status	staff only; updatedBy = auth.uid; archive, no delete
challengeSubmissions/{id}	uid, topic, title, minutes, status, reason	create pending; staff review; reason on reject
users/{uid}/inbox/{id}	kind, title, body, read	staff create; owner reads, may only flip read
announcements/{id}	title ≤ 80, body ≤ 1000, authorUid	staff create/delete; every signed-in user reads
users/{uid}/reports/{week}	isoWeek, fileName, sizeBytes, noteCount	owner only; id = week; savedAt = server time
users/{uid}/private/onboarding	answers, profileLabel, planSource	owner only; enums and sizes checked



Firestore Console · challenges

```
127   // the app inbox.
128   match /announcements/{id} {
129     allow read: if signedIn();
130     allow create: if isStaff()
131                   && request.resource.data.keys().hasOnly(['title', 'body',
132                   && request.resource.data.keys().hasAll(['title', 'body',
133                   && shortText(request.resource.data.title, 1, 80)
134                   && shortText(request.resource.data.body, 1, 1000)
135                   && request.resource.data.authorUid == request.auth.uid
136                   && request.resource.data.createdAt == request.time;
137     allow delete: if isStaff();
```

Rules for announcements (BR-04)

Indexes: submissions (uid, createdAt↓), (status, createdAt↓) · notes (groupId, createdAt↓) · full table: docs/data-model.md

Each workflow traces from screen to rule to test

FPT Education
FPT UNIVERSITY

WORKFLOW	SCREENS	CLASS / SERVICE	COLLECTION	TESTS
WF-01 Nốt AI	S03b Kể tự do	FreeTellViewModel · AiService	notes	BR-01 · free_tell_flow_test · ARTEMIS T18 (2/3), T19 (3/3)
WF-02 Share & review	S07 · Review queue · Inbox	CommunityActions · ReviewActions	challengeSubmissions · challenges · inbox	BR-02/03 · R-20…R-24 · ARTEMIS T20 (3/3) · D-1…D-3
WF-03 Announce news	Announcements · Inbox	AnnouncementActions	announcements · inbox	BR-04 · R-25 · notification_inbox_test · web checklist #9–11
Weekly PDF	S11b Thẻ tuần	WeeklyReportViewModel	reports	R-28 · weekly_report_test · ARTEMIS T14 (3/3)
Onboarding	S13a–g	OnboardingViewModel	private/onboarding	R-27 · onboarding_flow_test · ARTEMIS T17 (3/3)
Roles	Sign-in · Users	sessionProvider · UserActions	users	BR-05 · R-01, R-26, R-29 · session_test · auth_flow_test

Full matrix: docs/design-traceability.md · rules: firebase/tests/firestore.rules.test.js · E2E: e2e_test/

FPT Education
FPT UNIVERSITY

The demo is one evening: Minh logs his day, shares a card, staff publish it and announce

The result of each workflow is the input of the next.

01 · USER
Kể tự do: one paragraph → 3 notes saved

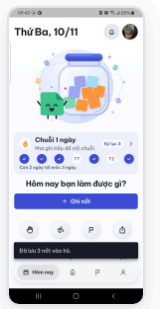
→

02 · USER → STAFF
Share "Đi bộ 10 phút" → staff approves → app shows it

→

03 · STAFF → USERS
"Bạn đã vận động chưa?" → every inbox

RESULT WF-01



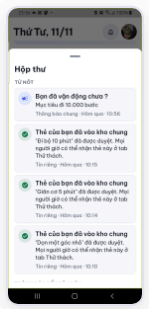
Jar 11 → 14 notes, streak starts

RESULT WF-02



Card "Người dùng đề xuất" in catalog; inbox message

RESULT WF-03



Announcement in app inbox at 10:56, same minute

EXCEPTION PATHS SHOWN LIVE

- Remote Config `ai_enabled = false` → "Nốt AI đang nghỉ", user writes by hand
- Reject without reason → blocked (BR-03) · user account on the web, staff account on the phone → rejected (BR-05)

Prepared: user account on a Galaxy A70 (release build, Play Integrity) · staff/admin account on the web admin · ai_enabled ready to toggle in Remote Config · empty review queue · backup video.

P3 DEMO 18 WF-01 · USER

WF-01 Log the day with Nốt AI: one paragraph becomes three editable notes

FPT Education
FPT UNIVERSITY

TRIGGER · PRECONDITION

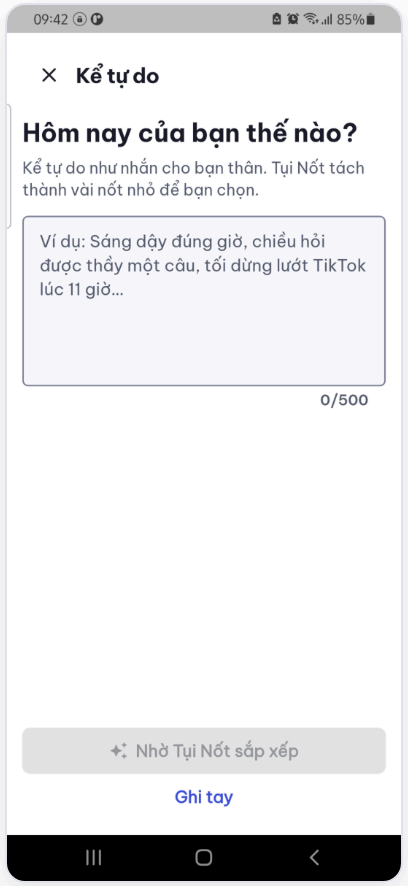
Evening, Ghi nốt → Kể tự do · role `user`, AI on (BR-01)

STEPS → RESULT

- Consent sheet on first use
- Scrubbed paragraph → Gemini → JSON notes + mood
- Labelled "Gợi ý từ Nốt AI", editable
- **Result:** chosen notes saved, jar and streak update

EXCEPTION

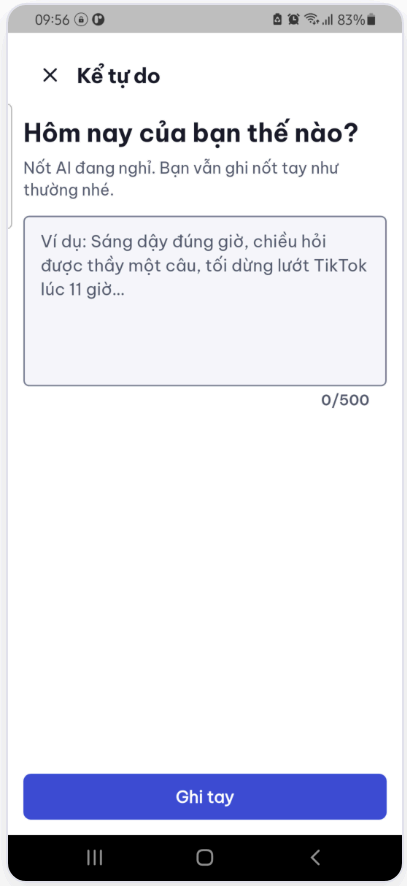
BR-01 fails (AI off, App Check, network) → "Ghi tay", paragraph kept



Consent



Suggestions



ai_enabled = false

Evidence: Galaxy A70, real Gemini (~2 s) · ARTEMIS T18 2/3, T19 (AI off) 3/3 · AI level 2: JSON schema → AiSortResult.

WF-02 Publish a card: staff approve on the web, the phone updates within seconds

FPT Education
FPT UNIVERSITY

TRIGGER · STATE

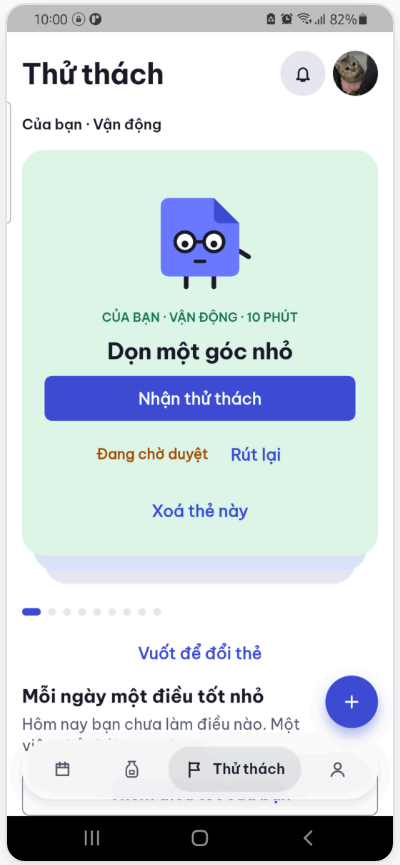
User shares own card · **pending** → **approved** / rejected

STEPS

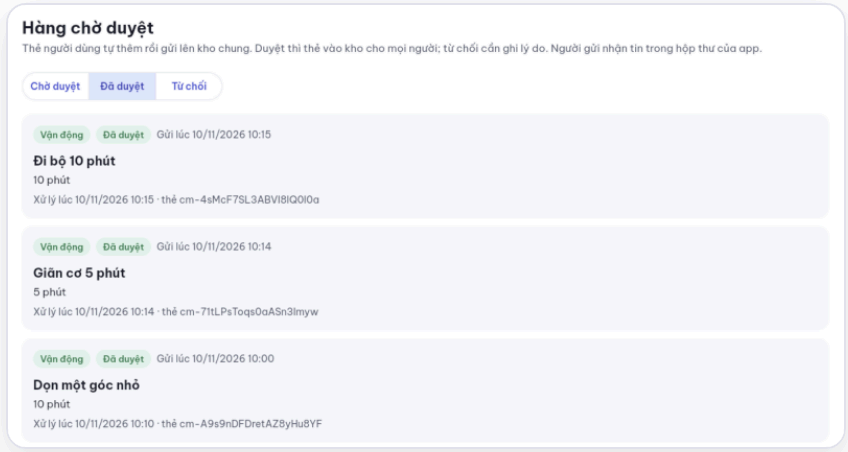
- User shares → pending
- Staff: Duyệt on the web
- Batch: card + status + inbox
- App: "Đã vào kho chung ✓"

EXCEPTION

BR-03 reason required · BR-02 user cannot approve



Đang chờ duyệt



Web: approved



App: inbox

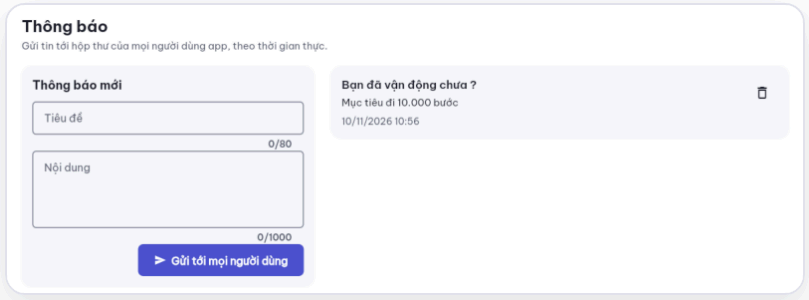
Evidence: write 1.4 s after Duyệt · phone ≤ 3.4 s (D-2, D-3), 22 s when idle (D-1) · ARTEMIS T20 3/3 · docs/cross-role-flow.md

P3 DEMO 20 WF-03 · STAFF

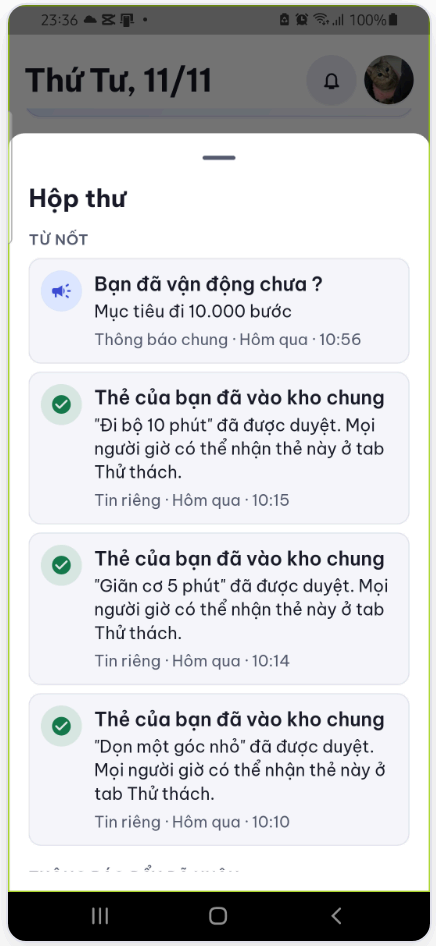
WF-03 Announce news to every user: staff post once, every inbox shows it in the same minute



1 · Compose (list still empty)



2 · Sent at 10:56, form cleared



3 · App inbox, 10:56

TRIGGER · PRECONDITION

Staff has news for every user · signed in as staff or admin

DECISION (BR-04)

Title 1–80 · body 1–1000 · authorUid = self, in the form and in the rules

RESULT

Announcement published; every user's inbox shows it in real time

EXCEPTION

Empty or too long → form error, nothing saved · user account → rejected at sign-in, rules deny (R-25)

Evidence: sent at 10:56, in the app inbox at 10:56 · rules R-25 (staff only, authorUid = self, title 1–80, body 1–1000) · web checklist #9–11.

FPT Education
FPT UNIVERSITY

Rules, code and the deployed system are each tested, with evidence in the repo

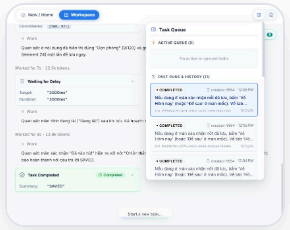
30/30
Security Rules tests

303
Flutter app tests

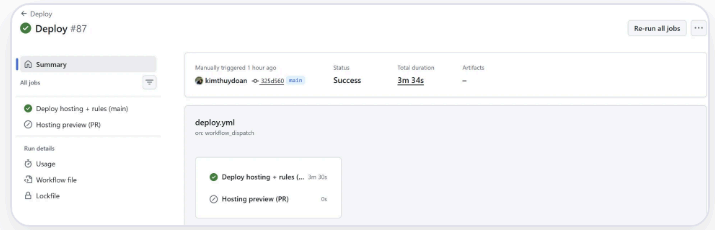
14 + 5
web admin + core tests

14/15
ARTEMIS Final runs, real phone

LEVEL	EVIDENCE	RESULT
Rules	Emulator, allowed + denied per role per collection (BR-02…BR-05)	30 / 30
Unit / widget	ViewModels, repositories, screens at 360 dp	all pass
Cross-role	3 runs on the deployed system, timed	3 / 3
Web checklist	Actions, rejection, empty, loading, error, live role change	16 / 16
Real device	Onboarding, Nốt AI, PDF, AI off, journal draft, role rejection on Galaxy A70	pass
E2E (ARTEMIS)	Lab 3: 41/42 · Final T14, T17–T20 on Galaxy A70: 14/15 · T15/T16 not run	14 / 15



ARTEMIS: agent reports SAVED



GitHub Actions: deploy on main

CI on every PR: format, analyze, all test suites, rules in the Emulator, web build, Android build, Hosting preview · details: docs/test-report.md.

P4 PROOF 22 ACHIEVEMENTS

FPT Education
FPT UNIVERSITY

Every brief requirement maps to a live feature and a piece of evidence

BRIEF REQUIREMENT	IMPLEMENTED	EVIDENCE
Web admin: 4 screens + announcement form, deployed	Dashboard, catalog, review, announcements, users	`evidence/web-admin/` (16 items)
Role-based rules, deny by default, tested	user / staff / admin, R-01…R-30	`evidence/firestore/rules-tests.txt`
Cross-role flow, real time, documented	Share card → approve → app + inbox	`docs/cross-role-flow.md`, `evidence/cross-role/`
AI level 2 with RC, App Check, fallback	Kể tự do on Gemini, `ai_*` flags incl. prompts, enforced App Check	`docs/ai-feature.md`, ARTEMIS T18/T19
App Check on Firestore and AI Logic	**Enforced** on both · Web: reCAPTCHA Enterprise; Android: Play Integrity	`evidence/app-check/`
Lab 3 PDF saved & shared on device	pdf + share_plus, metadata in Firestore	15.4 KB file pulled from the phone
Mobile data on Firestore with inbox	Announcements + personal inbox, real time	web checklist #11

Not met: ARTEMIS T15/T16 (email sign-in) not run → slide 23

P4 PROOF 23 LIMITATIONS & NEXT STEPS

What is not done yet, and what it costs

FPT Education
FPT UNIVERSITY

LIMITATION	IMPACT	PRIORITY	NEXT STEP
ARTEMIS T15/T16 (email sign-in) not run	Sign-out / sign-in by email has widget tests only, no E2E on a device	Medium	Create a test-only account, run 3× each
Names can reach Gemini (CR-F2)	Email and phone are scrubbed, but a friend's name is sent as typed	Medium	Consent sheet says so; add on-device name masking
Exploratory session X01: 10 UI issues not rechecked	Possible small layout bugs on rarely used screens	Low	Re-run X01 on the Final build, fix or close each
D-1 took 22 s on an idle phone	Real time not guaranteed after long idle	Low	Measure more runs; re-listen on resume
Lab 2 flow A3 (practice chat) dropped	Overlaps the Discord rooms; one designed flow not built	Low	Reason in docs/gap-review.md §1.1

FPT Education
FPT UNIVERSITY

Nốt is now a working multi-role system, and we can show every claim

1 · Problem solved

Content is curated by staff and grows from users' own cards; news reaches every user in the same minute.

2 · Working product

WF-01, WF-02, WF-03 run live on Android and the deployed web admin, on the free plan.

3 · Verified

30/30 rules tests, 300+ code tests in CI, 14/15 ARTEMIS runs on a real phone, 3 timed cross-role runs, App Check enforced.

prm393-not-lab3.web.app
prm393-not-lab3.web.app/admin/
github.com/FU-PRM-Projects/Lab-03
Thank you · Questions?

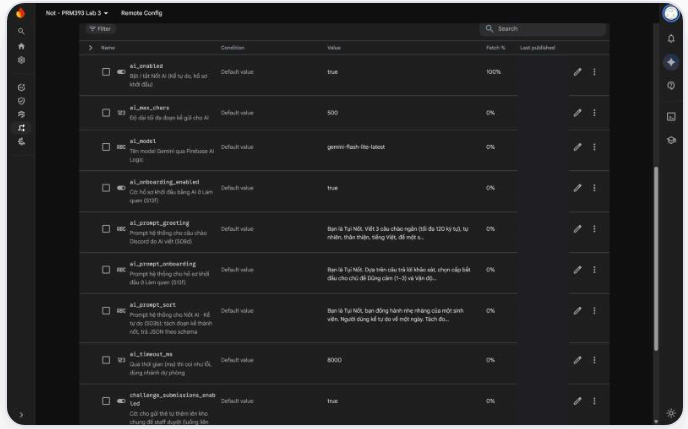
APPENDIX A1 · AI EXAMPLES

Three real Gemini inputs and outputs, and one handled failure

INPUT (KỂ TỰ DO)	GEMINI OUTPUT
Ran 2 km, ate a snack I meant to skip, calmed down without blaming myself	chien_thang "Chạy bộ 2km quanh hồ" · nhat_ky "Lỡ ăn thêm gói snack..." · tu_chu "Không tự trách và bình tĩnh lại" · mood binh_thuong
Asked a stranger in the library where to charge my phone; wrote a few lines about the rainy afternoon	chien_thang "Lấy hết can đảm hỏi mượn chỗ sạc pin" · nhat_ky "Ghi lại vài dòng cảm xúc buổi chiều mưa" · mood vui
Tired for days, only tidied my desk today	chien_thang "Mình đã dọn dẹp được cái bàn học" · 2× nhat_ky · mood met · needs_support false
Handled failure	404 model retired / 401 missing App Check → `ai_error` logged, paragraph kept, "Ghi tay" offered; fixed by Remote Config model name

```
29
30  GenerativeModel _model(String instructions, Schema schema) =>
31      FirebaseAI.googleAI().generativeModel(
32        model: config.model,
33        systemInstruction: Content.system(instructions),
34        generationConfig: GenerationConfig(
35          responseMimeType: 'application/json',
36          responseSchema: schema,
37          temperature: 0.4,
38        ),
39      );
```

JSON schema forces the answer shape

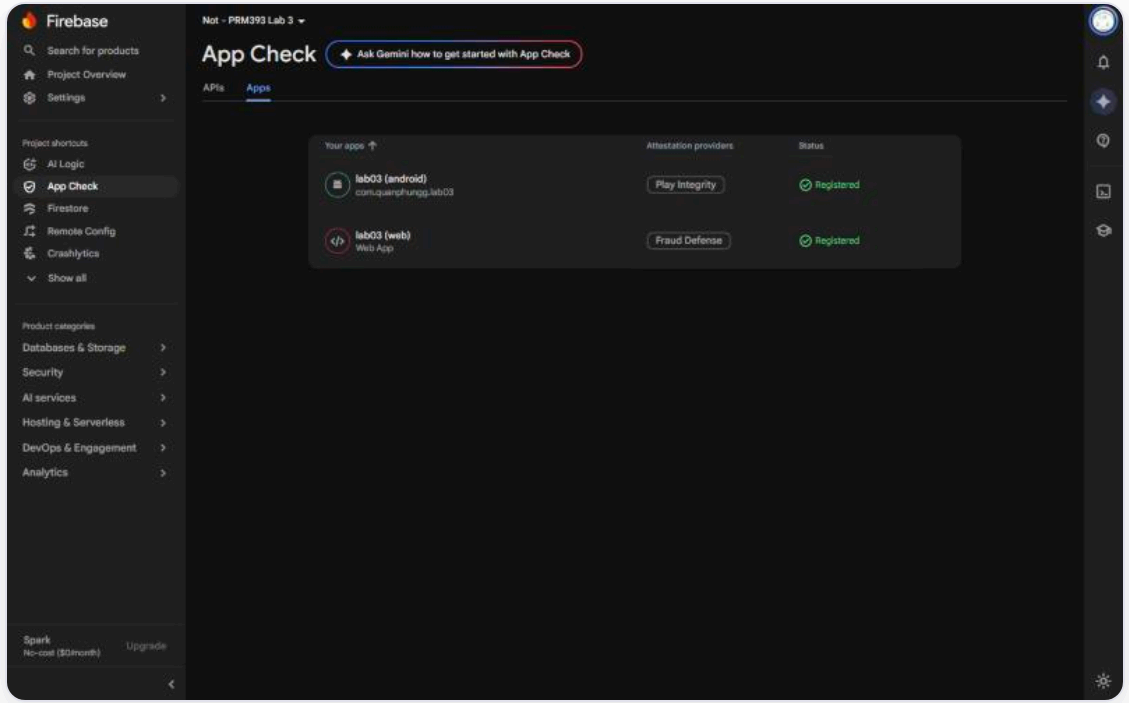


Remote Config: model, prompts, on/off

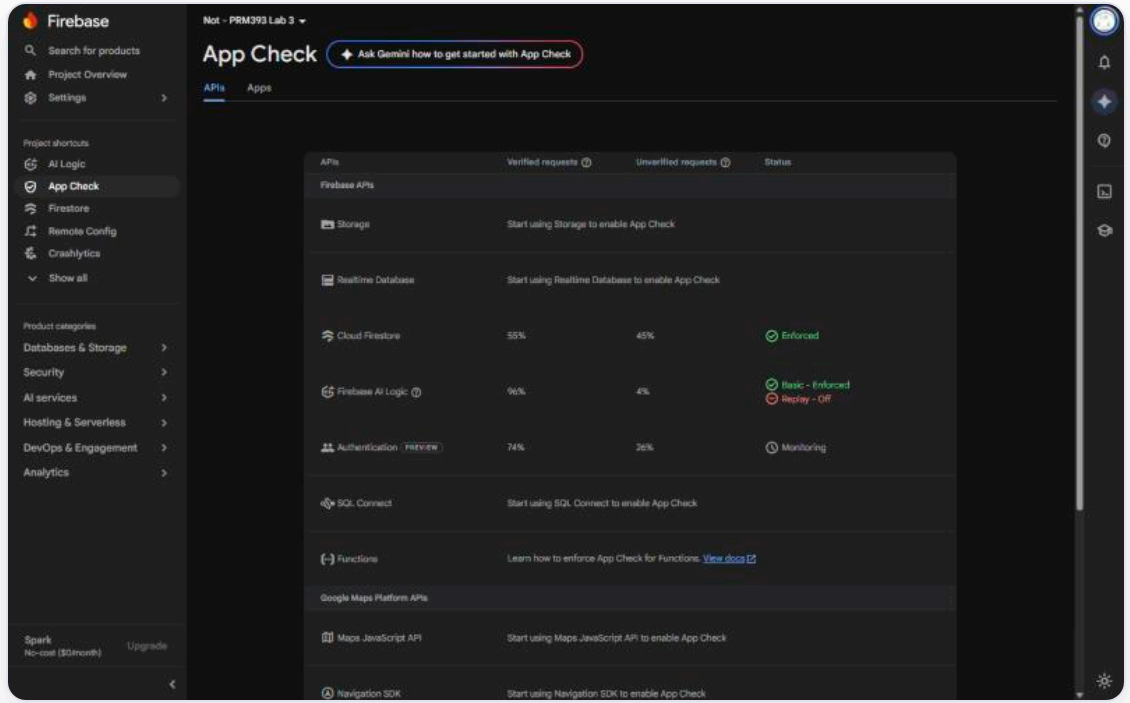
Inputs are scrubbed (email, phone) and capped at 500 characters; no names, emails or photos are sent.

FPT Education
FPT UNIVERSITY

Both apps are registered, and Firestore and AI Logic are enforced



Apps: lab03 (android) Play Integrity · lab03 (web) Fraud Defense



Cloud Firestore: Enforced · AI Logic: Enforced

Web: reCAPTCHA Enterprise (Fraud Defense) · Android: Play Integrity (debug builds need a registered debug token) · enforced 12/11/2026 · evidence/app-check/.

APPENDIX A3 · LESSONS LEARNED

FPT Education
FPT UNIVERSITY

Running the system for real found bugs the tests did not

Five bugs surfaced only against the real project or a real device; all are fixed, with regression tests.

APPROVE TIMED OUT

Riverpod paused the unwatched catalog provider; approval waited 10 s and failed. Found while timing D-1. Fixed: read the repository once (PR #70).

DASHBOARD SPUN OFFLINE

`count()` waits for the server forever. Found while shooting the error state. Fixed: 15 s timeout → error state (PR #71).

ERROR STATES 3 MIN LATE

Riverpod 3 retried failed providers 10× while showing loading. Found on the deployed web admin. Fixed: `retry: noRetry` in both apps (PR #77).

ROLE READ ONLY ONCE

A demoted staff kept the admin UI until reload (CR-F1). Fixed: the session follows the user's role document live (PR #75).

GEMINI MODEL RETIRED

`gemini-2.5-flash` returned 404 for new projects. Fixed: default `gemini-flash-lite-latest`, model stays in Remote Config.

AI NEEDS A PLAN B

App Check, quota and model changes all broke AI at some point; the hand-written path kept the flow alive.